

APP.4.7 Zeitreihen-Datenbanken

1 Beschreibung

1.1 Einleitung

Zeitreihen-Datenbanken (Time-Series Databases, TSDB) sind hochspezialisierte Datenbanksysteme, die für das Speichern, Verwalten und Auswerten von Daten mit einem Zeitstempel optimiert sind. Systeme wie Prometheus, InfluxDB oder TimescaleDB bilden das Fundament für modernes IT-Monitoring, die Analyse von Anwendungs-Metriken und die Verarbeitung von Daten aus dem Internet der Dinge (IoT).

Ihre Architektur ist auf extrem hohe Schreiblasten und schnelle, aggregierte Abfragen über definierte Zeiträume ausgelegt. Dies führt zu spezifischen Betriebsmodellen, wie dem Abrufen ("Scraping") von Metrik-Endpunkten oder der Entgegennahme von massiven Datenströmen unzähliger Sensoren und Agenten. Diese Besonderheiten bringen spezifische Sicherheitsherausforderungen mit sich: ungeschützte HTTP-Endpunkte, die sensible Systeminformationen preisgeben, das Risiko der Datenmanipulation durch kompromittierte Agenten und die Notwendigkeit, ressourcenintensive Abfragen (mit hoher Kardinalität) zu kontrollieren.

1.2 Zielsetzung

Ziel dieses Bausteins ist es, einen systematischen Weg aufzuzeigen, um Zeitreihen-Datenbanken und die zugehörigen Ökosysteme aus Agenten und Endpunkten sicher zu konfigurieren und zu betreiben. Im Fokus stehen der Schutz der Vertraulichkeit der oft sensiblen Monitoring-Daten, die Gewährleistung der Integrität der erfassten Messwerte sowie die Sicherstellung der Verfügbarkeit der zentralen Metrik- und Monitoring-Infrastruktur.

1.3 Abgrenzung und Modellierung

Der Baustein APP.4.7 ist auf alle eingesetzten Zeitreihen-Datenbanken anzuwenden. Er ergänzt das IT-Grundschutz-Kompendium im Bereich der spezialisierten Datenhaltung und grenzt sich von klassischen relationalen Datenbanken ab (siehe APP.4.3 *Relationale Datenbanksysteme*).

Dieser Baustein behandelt nicht die grundlegende Absicherung des unterliegenden Servers; hierfür sind die Bausteine SYS.1.1 *Allgemeiner Server* und OPS.1.1.1 *Allgemeiner IT-Betrieb* anzuwenden. Ebenso ist die sichere Entwicklung der Anwendungen, die Metriken bereitstellen, nicht Gegenstand dieses Bausteins. Hierfür sind die Bausteine CON.10 *Entwicklung von Webanwendungen* oder APP.7 *Entwicklung von Individualsoftware (auftraggebende Seite)* heranzuziehen.

2 Gefährdungslage

Für den Baustein APP.4.7 sind folgende spezifische Gefährdungen von besonderer Bedeutung:

Manipulation von Messdaten

Gelingt es einem Angreifer, gefälschte Metrik-Daten in die Zeitreihen-Datenbank zu schreiben, kann die Überwachung der IT-Systeme untergraben werden. Angriffe können verschleiert werden, indem Leistungsdaten (z. B. CPU-Auslastung) künstlich niedrig gehalten werden. Ebenso können gezielt Fehlalarme ausgelöst werden, um von einem realen Vorfall abzulenken oder das Betriebspersonal zu ermüden.

Unautorisiertes Auslesen von Monitoring-Daten

Monitoring-Daten geben tiefe Einblicke in die Infrastruktur, die Auslastung von Anwendungen und teilweise sogar in Geschäftsmetriken. Ungeschützte Abfrage-APIs ermöglichen es Angreifern, wertvolle Informationen für die Vorbereitung weiterer Angriffe zu sammeln, indem sie Schwachstellen, Patch-Stände oder wenig genutzte Systeme identifizieren.

Offene und ungeschützte Metrik-Endpunkte

Anwendungen und Systeme, die von pull-basierten Zeitreihen-Datenbanken überwacht werden, stellen ihre Metriken oft über ungeschützte HTTP-Endpunkte bereit. Sind diese aus nicht vertrauenswürdigen Netzwerken erreichbar, können Angreifer detaillierte Informationen über Softwareversionen, Abhängigkeiten und die interne Funktionsweise der Anwendung auslesen.

Denial-of-Service durch Daten- oder Abfrageflut

Zeitreihen-Datenbanken sind anfällig für Angriffe, die auf die Erschöpfung von Ressourcen abzielen. Ein Angreifer kann durch das Senden von Daten mit extrem hoher Varianz (hohe Kardinalität) den Speicher und die CPU der Datenbank überlasten. Ebenso können komplexe, langlaufende Abfragen das System lahmlegen und so die gesamte Überwachungsinfrastruktur zum Ausfall bringen.

Kompromittierung über unsichere Web-Schnittstellen

Viele Zeitreihen-Datenbanken werden mit integrierten Web-Oberflächen und mächtigen HTTP-APIs für Konfiguration und Abfrage ausgeliefert. Sind diese Schnittstellen nicht ausreichend gehärtet, können sie Angreifern als Einfallstor zur vollständigen Übernahme der Datenbank oder des darunterliegenden Hosts dienen.

3 Anforderungen

Im Folgenden sind die spezifischen Anforderungen des Bausteins APP.4.7 aufgeführt. Grundsätzlich ist der IT-Betrieb für die Erfüllung der Anforderungen zuständig. Abweichungen werden in den entsprechenden Anforderungen gesondert genannt.

Zuständigkeiten	Rollen
Grundsätzlich zuständig	IT-Betrieb
Weitere Zuständigkeiten	Planer, Fachverantwortliche

3.1 Basis-Anforderungen

Die folgenden Anforderungen MÜSSEN vorrangig erfüllt werden.

APP.4.7.A1 Planung des Einsatzes von Zeitreihen-Datenbanken (B) **[Planer]**

Vor dem Einsatz einer Zeitreihen-Datenbank MUSS eine Anforderungsanalyse durchgeführt werden. Dabei MÜSSEN die benötigten Kapazitäten, das Mengengerüst für zu verarbeitende Metriken sowie die Sicherheitsanforderungen an die gespeicherten Daten ermittelt werden. Basierend darauf MUSS ein sicheres Architektur- und Betriebskonzept erstellt werden.

APP.4.7.A2 Absicherung des Netzwerkzugriffs auf die Datenbank (B)

Der Netzwerkzugriff auf die Zeitreihen-Datenbank MUSS strikt auf die Systeme beschränkt werden, die Daten schreiben oder lesen müssen. Die Datenbank MUSS netzwerktechnisch durch eine Firewall geschützt werden. Dienste DÜRFEN NICHT an öffentliche oder ungeschützte Netzwerkschnittstellen gebunden werden.

APP.4.7.A3 Aktivierung der Authentifizierung für Schreib- und Lesezugriffe (B)

Alle Schreib- und Lesezugriffe auf die Datenbank MÜSSEN authentifiziert werden. Es MÜSSEN sichere Passwörter oder kryptografisch starke Authentifizierungs-Token verwendet werden. Ein anonymer Zugriff auf produktive Daten MUSS deaktiviert werden.

APP.4.7.A4 Absicherung der administrativen Schnittstellen (B)

Der Zugriff auf administrative Web-Oberflächen und Konfigurations-APIs MUSS durch starke, nicht standardisierte Anmeldedaten geschützt sein. Standard-Benutzerkonten MÜSSEN umbenannt oder serverseitig deaktiviert werden.

APP.4.7.A5 Schutz von Metrik-Endpunkten (B)

Metrik-Endpunkte, die von pull-basierten Systemen (z. B. Prometheus) abgefragt werden, MÜSSEN so konfiguriert sein, dass sie ausschließlich für das legitime Monitoring-System erreichbar sind. Dies MUSS durch Netzsegmentierung oder hostbasierte Firewall-Regeln sichergestellt werden.

3.2 Standard-Anforderungen

Gemeinsam mit den Basis-Anforderungen entsprechen die folgenden Anforderungen dem Stand der Technik bei normalem Schutzbedarf. Sie SOLLTEN grundsätzlich erfüllt werden.

APP.4.7.A6 Verschlüsselung der gesamten Kommunikation (S)

Die gesamte Kommunikation mit der Zeitreihen-Datenbank SOLLTE mittels TLS verschlüsselt werden. Dies umfasst die Verbindung von Agenten und Sensoren zur Datenbank, die Abfragen von Administratoren und Dashboards sowie die Kommunikation zwischen den Knoten innerhalb eines Datenbank-Clusters.

APP.4.7.A7 Umsetzung eines differenzierten Berechtigungskonzepts (S)

Es SOLLTE ein Berechtigungskonzept nach dem Prinzip der geringsten Rechte (Least Privilege) umgesetzt werden. Schreibende Agenten SOLLTEN nur Berechtigungen für die von ihnen benötigten Namensräume oder Metriken erhalten. Lesende Benutzer SOLLTEN ausschließlich auf die für ihre Rolle relevanten Daten zugreifen können.

APP.4.7.A8 Systematische Verwaltung von Datenaufbewahrungszeiten (S) [Fachverantwortliche]

Es SOLLTEN Richtlinien für die Aufbewahrung von Daten (Retention Policies) definiert und technisch in der Datenbank umgesetzt werden. Um unkontrolliertes Speicherwachstum zu verhindern, SOLLTEN veraltete Daten nach einer definierten Frist automatisch gelöscht oder in ihrer Granularität reduziert werden (Downsampling).

APP.4.7.A9 Protokollierung und Überwachung sicherheitsrelevanter Ereignisse (S)

Administrative Änderungen, fehlgeschlagene Anmeldeversuche und kritische Systemereignisse der Datenbank SOLLTEN protokolliert und an ein zentrales Log-Management übergeben werden. Die Protokolle SOLLTEN regelmäßig auf Anomalien und Angriffsversuche ausgewertet werden.

3.3 Anforderungen bei erhöhtem Schutzbedarf

Die folgenden Anforderungen sind exemplarisch und bei erhöhtem Schutzbedarf zu berücksichtigen; die konkrete Festlegung erfolgt im Rahmen einer Risikoanalyse. Der Schutzziel-Bezug ist am Ende jeder Anforderung in Klammern angegeben (C = Vertraulichkeit, I = Integrität, A = Verfügbarkeit).

APP.4.7.A10 Erzwingung gegenseitiger Authentifizierung (mTLS) (H)

Für die Kommunikation zwischen hochsensiblen Datensammlern und der Zeitreihen-Datenbank

SOLLTE eine gegenseitige Authentifizierung mittels TLS (mTLS) erzwungen werden. Sowohl der Client als auch der Server SOLLTEN ihre Identität dabei durch gültige Zertifikate nachweisen. (C, I)

APP.4.7.A11 Verschlüsselung der gespeicherten Daten (Encryption at Rest) (H)

Werden in der Zeitreihen-Datenbank besonders schützenswerte Informationen gespeichert, SOLLTEN die Daten auf dem Speichermedium verschlüsselt werden. Dies SOLLTE durch Verschlüsselungsmechanismen des Betriebssystems oder durch native Funktionen der Datenbank umgesetzt werden. (C)

APP.4.7.A12 Begrenzung von Ressourcen für Abfragen (H)

Um Denial-of-Service-Angriffe durch missbräuchliche Abfragen oder übermäßige Metrik-Kardinalität zu verhindern, SOLLTEN technische Limitierungen in der Datenbank implementiert werden. Dies SOLLTE die maximale Laufzeit einer Abfrage, die maximale Anzahl der zurückgegebenen Datenpunkte und Speicherlimits für einzelne Abfragen umfassen. (A)

APP.4.7.A13 Sicherstellung der Datenintegrität durch kryptografische Signaturen (H)

In Umgebungen mit geringem Vertrauen in das transportierende Netzwerk oder die datenliefernden Endpunkte SOLLTEN die Messwerte direkt am Agenten kryptografisch signiert werden. Ein vorgeschalteter Dienst oder die Datenbank selbst SOLLTE die Signatur jeder eingehenden Nachricht kryptografisch überprüfen, bevor die Daten persistent gespeichert werden. (I)

4 Weiterführende Informationen

4.1 Wissenswertes

Für die sichere Konfiguration und den Betrieb von Zeitreihen-Datenbanken existieren herstellerspezifische Leitfäden und Best Practices, die ergänzend herangezogen werden sollten. Relevante Quellen umfassen unter anderem:

- **Offizielle Dokumentationen der Hersteller**, z. B. die Sicherheitsrichtlinien und Härtungsempfehlungen für Prometheus und InfluxDB.
- **BSI TR-02102-2: Kryptographische Verfahren: Empfehlungen und Schlüssellängen – Teil 2: Verwendung von Transport Layer Security (TLS)**, für Vorgaben zur sicheren TLS-Konfiguration der APIs.

Kreuzreferenztable zu elementaren Gefährdungen

Die folgenden elementaren Gefährdungen sind für den Baustein APP.4.7 von Bedeutung:

- G 0.14 Ausspähen von Informationen (Spionage)
- G 0.18 Fehlplanung oder fehlende Anpassung
- G 0.19 Offenlegung schützenswerter Informationen
- G 0.21 Manipulation von Hard- oder Software
- G 0.22 Manipulation von Informationen
- G 0.23 Unbefugtes Eindringen in IT-Systeme
- G 0.27 Ressourcenmangel
- G 0.28 Software-Schwachstellen oder -Fehler
- G 0.40 Verhinderung von Diensten (Denial of Service)
- G 0.46 Integritätsverlust schützenswerter Informationen

Anforderung	G 0.14	G 0.18	G 0.19	G 0.21	G 0.22	G 0.23	G 0.27	G 0.28	G 0.40	G 0.46
APP. 4.7.A 1 (B)		X					X			
APP. 4.7.A 2 (B)	X		X			X				
APP. 4.7.A 3 (B)	X		X		X	X				
APP. 4.7.A 4 (B)				X		X		X		
APP. 4.7.A 5 (B)	X		X							
APP. 4.7.A 6 (S)	X		X							
APP. 4.7.A 7 (S)	X		X		X	X				

APP. 4.7.A 8 (S)							X			
APP. 4.7.A 9 (S)				X		X				
APP. 4.7.A 10 (H)					X	X				X
APP. 4.7.A 11 (H)	X		X							
APP. 4.7.A 12 (H)							X		X	
APP. 4.7.A 13 (H)					X					X